JÖNKÖPING UNIVERSITY

School of Engineering

Nätverksdesign – Trådlösa nätverk

802.11 MAC
&
Trådlös säkerhet

Agenda

- Medium access
  - CSMA/CD
  - CSMA/CA
  - Overhead
- 802.11 Frames
  - Adressering
  - Frame types
- Wireless security
  - Legacy security
  - 802.11i Robust Security
  - WPA2 Personal
  - WPA2 Enterprise
  - WPA3
  - Säkerhetsaspekter
  - Trådlösa attacker

JÖNKÖPING UNIVERSITY

School of Engineering

Nätverksdesign – Trådlösa nätverk
Föreläsning 4
Del 1

Medium Access

Medium access

- All kommunikation som delar ett medium behöver någon form av Media Access Control för att styra tillgången

- Media Access metoden i halv-duplex Ethernet är CSMA/CD
- För 802.11 används metoden CSMA/CA

- Dessa brukar kallas för contention-based MAC metoder på engelska
  - Löst översatt innebär *contention* strid eller tävla – d.v.s. stationer tävlar om åtkomst till mediet

CSMA/CD

- *Carrier sense multiple access with collision detection* används i Ethernet
- *Carrier sense* innebär att klienten lyssnar på mediet för att avgöra om det är ledigt eller upptagen av annan sändning
- När mediet anses tillgängligt kommer klienten direkt påbörja sin sändning

- Under sändningen fortsätter klienten övervaka kanalen för att upptäcka eventuella kollisioner
- Om en kollision upptäcks under sändning, kommer stationen sluta sända (back off)
- Efter den har slutat sända väntar den en slumpad tid (random backoff timer) innan den på nytt försöker med sändningen

CSMA/CD

Collision detection som i halv-duplex Ethernet är inte möjligt med 802.11

Varför kan vi inte upptäcka kollisioner i trådlösa nätverk?

Förklaring: 802.11 radios kan inte både lyssna och sända samtidigt

CSMA/CA

- *Carrier sense multiple access with collision avoidance* används i 802.11
- Istället för att förlita sig på att upptäcka kollisioner kommer CSMA/CA ta flera åtgärder för att helt försöka undvika kollisioner från början

- Precis som med CSMA/CD behöver deltagande stationer först lyssna på mediet (carrier sense) för att avgöra om det är upptaget eller ej
- När mediet anses tillgängligt kommer station vänta en kort slumpad tidsperiod *(random backoff timer)* innan den påbörjar sändning
- Först när den har väntat ut *random backoff timer* kommer den påbörja sändningen, men endast **om** mediet fortfarande är ledigt

CSMA/CA

- CSMA/CA är inte perfekt. Kollisioner kommer fortfarande uppstå i nätverket
- Eftersom vi inte kan upptäcka när en kollision sker behöver vi ett annat sätt att veta att sändningen har lyckats
- P.g.a. detta använder sig 802.11 av CRC och lager2 ACKs för att säkerställa leverans
  - En mottagare kommer beräkna en CRC *(cyclic redundancy check)* på mottagen frame och jämför denna med CRC-värdet i 802.11 trailern
  - Om det matchar svarar den med en ACK, och om den visar på fel i framen kommer den avvakta och vänta på att transmittern skickar om framen

- Varje 802.11 data frame kommer alltså behöva ACKas!

CSMA/CA - DCF

- Den ursprungliga media access metoden i 802.11 är *Distributed Coordination Function* (DCF)

- DCF har tre primära komponenter:
  - Carrier sense (physical & virtual)
  - Interframe space
  - Random backoff time

DCF – Physical Carrier Sense

- En station som inte aktivt sänder kommer kontinuerligt lyssna på mediet (kanalen)

- Innan den påbörjar en sändning kommer den göra en avvägning huruvida kanalen är ledig, funktionen kallas för *clear-channel assessment (CCA)*

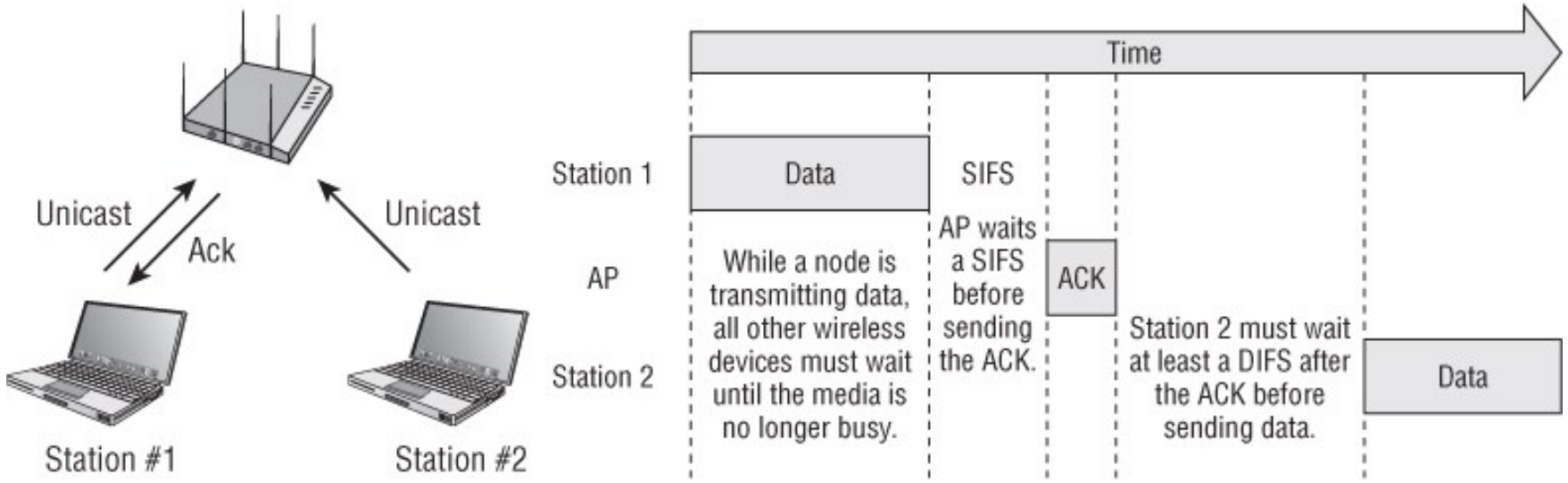
- CCA kommer upptäcka andra 802.11 sändningar på kanalen med signalstyrka över ett visst gränsvärde *(signal detect)*
- CCA kommer också upptäcka icke-802.11 källor som har en effekt på mediet med ett annat gränsvärde *(energy detect)*

DCF – Interframe space

- *Interframe space* (IFS) är en tidsperiod mellan varje wireless frame som skickas och nästkommande frame
- Varje station som har något att sända måste vänta en viss *interframe space period* innan den får försöka ta mediet och påbörja sin sändning
- Syftet med IFS är att ge prioritet till stationer baserat på vilken typ av frame de vill skicka ut på mediet
  - Till exempel, så att ett komplett frame-utbyte (inkl. ACK) kan ske innan någon annan station avbryter

- Det finns flera olika längder på en *interframe space period,* men vi kommer bara kolla på två varianter:
  - Short interframe space (SIFS)
    - Kort tidsperiod och hög prioritet, används när en station behöver skicka en ACK
  - DCF interframe space (DIFS)
    - Längre tidsperiod och därmed lägre prioritet, används för de flesta data frames

DCF – Interframe space



DCF – Virtual carrier sense

- CSMA förlitar sig inte enbart på fysisk carrier sense med CCA
- För virtuell carrier sense används också en speciell NAV-timer *(network allocation vector)*
- NAV-timern är ett sätt för stationer att hålla koll på hur länge ett medie är upptaget p.g.a. en annan sändning

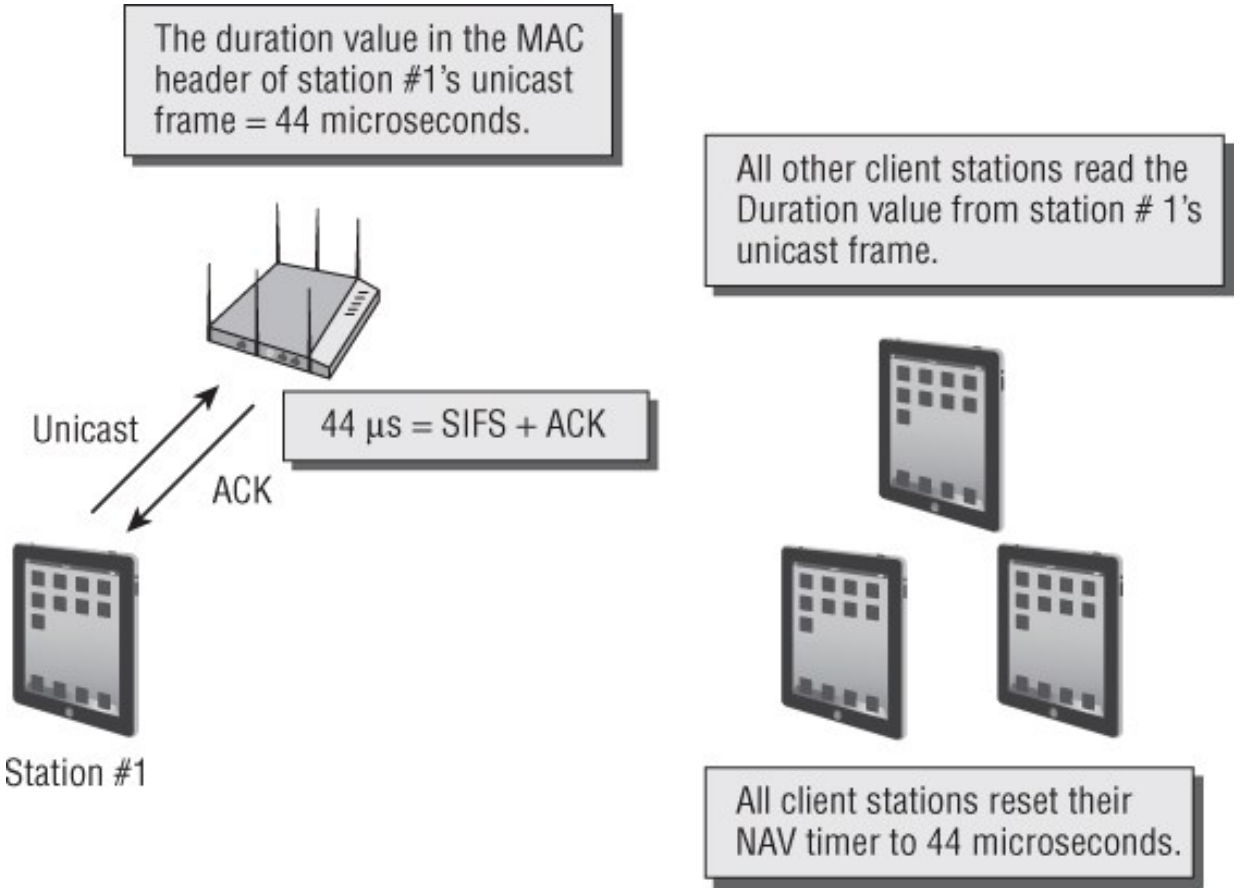
- NAV-timern uppdateras genom att stationer meddelar varandra hur länge en viss frame exchange kommer pågå
- Detta görs genom att sändaren lägger in ett tidsvärde i *Duration* fältet på varje 802.11 frame header

DCF – Virtual carrier sense

- Tidsvärdet som läggs i *Duration* är angivet i mikrosekunder
- Detta inkluderar tiden det tar för den faktiska framen, plus tiden som behövs för en ACK

- Alla stationer som lyckas läsa av 802.11 headern vet då hur länge mediet är upptaget
- Värdet från *Duration* läggs till i NAV-timern som hela tiden räknas ner på en station
- Först när NAV är 0 kan varje station försöka ta tillgång till mediet

DCF – Virtual carrier sense



DCF – Carrier sense

- Med fysisk och virtuell carrier sense har en station flera kontroller för att avgöra när mediet är ledigt eller ej
- När en station har gjort en lyckad *CCA* och *NAV-timern* är 0 är mediet ledig och en sändning skulle kunna påbörjas

- Eftersom närliggande stationer kommer komma till samma slutsats om ledig kanal samtidigt behöver det finnas ytterligare skydd för att förhindra kollisioner
- Detta skydd kallas för *random backoff timer*

DCF – Random backoff time

- När en station har en frame att skicka kommer den slumpa fram en tidsperiod som den behöver vänta ut innan den får skicka
- Denna *random backoff timer* behöver bli 0 innan sändning påbörjas

- För att inte behöva vänta för länge räknas timern endast ner när kanalen är ledig
- Eftersom varje station slumpar fram en *backoff time* är det osannolikt att två stationer når 0 samtidigt – kollisioner kan effektivt undvikas

Vi har alltså två timers i CSMA/CA:
- *NAV-timern* håller koll på hur länge kanalen är upptagen
- *Random backoff* timern används för att två stationer ska undvika att skicka samtidigt på en ledig kanal

CSMA/CA Overhead

- Det är många åtgärder som sker i DCF för att undvika kollisioner, dessa lägger till overhead i 802.11
- Varje 802.11 data frame behöver också ACKas vilket bidrar till mer overhead

- Media access och CSMA/CA är en av huvudanledningarna till att den faktiska throughput vi får i Wi-Fi är mycket lägre än max data-rate som används!

CSMA/CA tillägg (802.11e)

- 802.11e tillägget introducerar flera förbättringar till DCF med en alternativ access metod
- *Hybrid Coordination Function (HCF)* minskar mängden overhead och lägger till QoS-funktionalitet

HCF fungerar likt DCF, men effektiviserar genom att:

- En klient får möjlighet att skicka flera frames i taget i ett s.k. *transmit opportunity* när den har tillgång till ett ledigt medium
- En AP kan ACKa mottagandet av flera frames genom en s.k. *Block ACK*

JÖNKÖPING UNIVERSITY

School of Engineering

Nätverksdesign – Trådlösa nätverk

Del 2
802.11 Frame

802.11 Data-Link & Physical layer

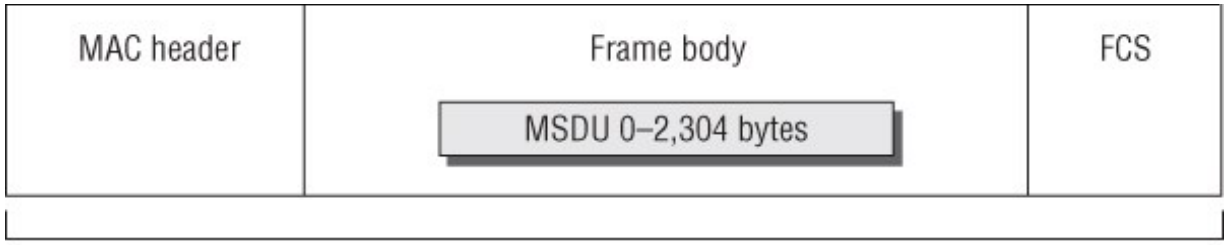
- 802.11 arbetar i Data-Link- och Physical-lagret i OSI-modellen

- På lager 2 kommer data från ovanstående OSI-lager kapslas in i en 802.11 frame
  - 802.11 framen består av en *MAC header*, *Frame Body* och en *trailer (FCS)*

- På lager 1 förbereds framen för sändning genom att en *preamble* och en *PHY header* läggs till i början av ramen
- Dessa används för att styra och synkronisera kommunikationen mellan sändare och 802.11-mottagare
- Lager 1 har också ansvar för moduleringen – d.v.s. representationen av bitar

802.11 Header och Trailer

- Framen har en *MAC-header* med adresser, en frame body som bär en payload, och en FCS (trailer) för error-detection
- FCS är en CRC checksum, precis som i Ethernet
- En 802.11 data frame har en max payload på 2304 bytes (jämfört med 1500 i ethernet)



MPDU—802.11 data frame

802.11 Adressering

- Adressering i 802.11 liknar Ethernet
  - Unicast-, Multicast- och Broadcast-adresser

- En 802.11 header innehåller däremot upp till fyra olika MAC-adress fält!
- Hur många av dessa fält som används och adressernas innebörd beror på vilken station som skapade framen och det slutgiltiga målet

Om alla fyra adresser används kan varje adress definieras som:

Address #1:	Receiver Address (RA)	*Adressen för mottagande radio*
Address #2:	Transmitter Address (TA)	*Adressen för sändande radio*
Address #3:	Destination Address (DA)	*Slutdestinationen för framen*
Address #4:	Source Address (SA)	*Stationen som skapade framen*

802.11 Adressering

802.11 Mac header

Bytes	2	2	6	6	6	2	6	2
	Frame control	Duration/ ID	Address 1	Address 2	Address 3	Sequence control	Address 4	QoS control

Om alla fyra adresser används kan varje adress definieras som:

Address #1:	Receiver Address (RA)	*Adressen för mottagande radio*
Address #2:	Transmitter Address (TA)	*Adressen för sändande radio*
Address #3:	Destination Address (DA)	*Slutdestinationen för framen*
Address #4:	Source Address (SA)	*Stationen som skapade framen*

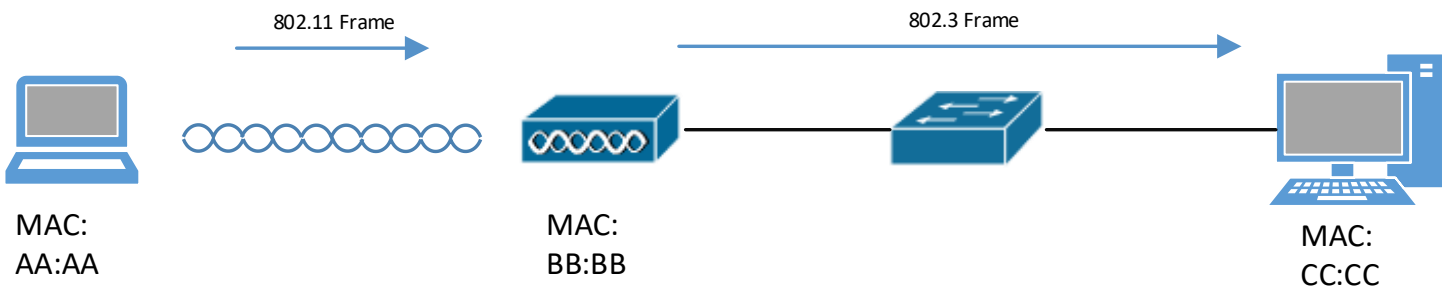
802.11 Adressering

- *Receiver address (RA)* och *Transmitter address (TA)* kommer alltid finnas i 802.11 headern
- Resten av adressfälten fylls i om nödvändigt för kommunikationen

När tror ni att vi behöver använda oss av fler än två adresser?

802.11 Adressering

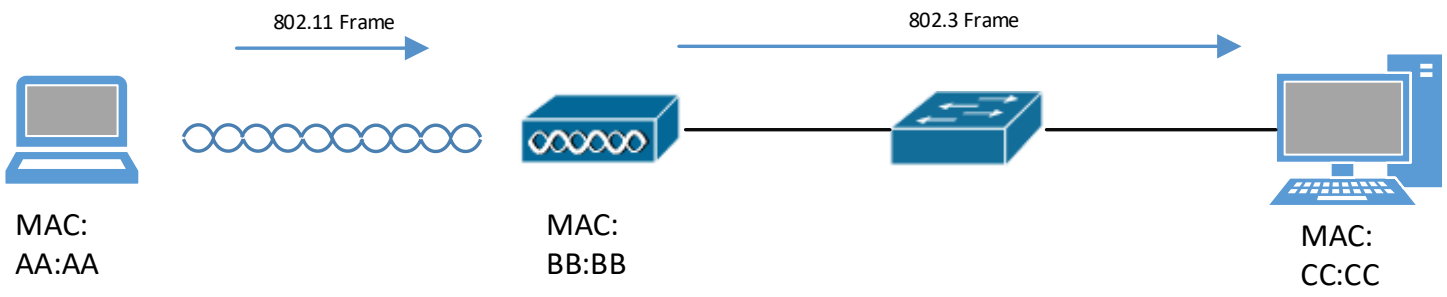
- Den flesta frames kommer använda tre adresser, eftersom accesspunkten fungerar som en relä för all kommunikation
  - *RA (address 1) och TA (address 2)* kommer vara adresserna på de radio som sänder signalen
  - Den tredje adressen är antingen *source* eller *destination address* beroende på om framen är på väg till eller från distributionssystemet
    - Indikeras med en *"To DS"* eller *"From DS"* bit i framen – 1 eller 0



802.11 Adressering

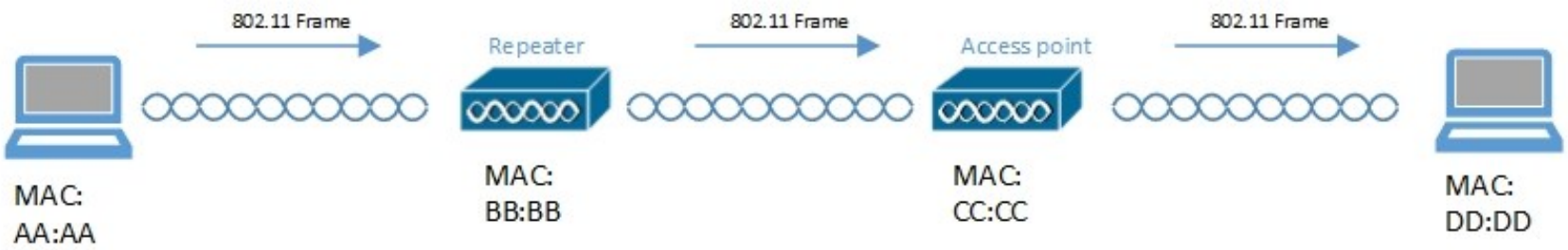
From DS: 0
To DS: 1
Address 1 (RA): BB:BB
Address 2 (TA): AA:AA
Address 3 (DA): CC

Destination address: CC:CC
Source address: AA:AA



802.11 Addressing

- Fyra adresser används när vi har ett *Wireless Distribution System (WDS)* istället för ett vanligt Ethernet DS
- Det vanligaste exemplet på ett WDS är när man skapar mesh-nätverk eller använder *repeaters*
- I ett WDS behöver inblandade enheter hålla koll på vem som skickar *(RA)* och tar emot *(TA)* över en länk, samt vem som skapade framen *(SA)* och vem slutmålet är (DA)



802.11 Adressering

Även fast de flesta scenarion endast använder tre adressfält kommer wireshark underlätta genom att alltid visa alla fyra adresser och dess innebörd!

För att inte komplicera saker mer än nödvändigt, kan ni också i kursen (och tentan) alltid anta att alla fyra adresser används och ignorera användandet av ”DS”-biten

- **Receiver Address (RA)** – *Adressen för mottagande radio*
- **Transmitter Address (TA)** – *Adressen för sändande radio*
- **Destination Address (DA)** – *Slutdestinationen för framen*
- **Source Address (SA)** – *Stationen som skapade framen*

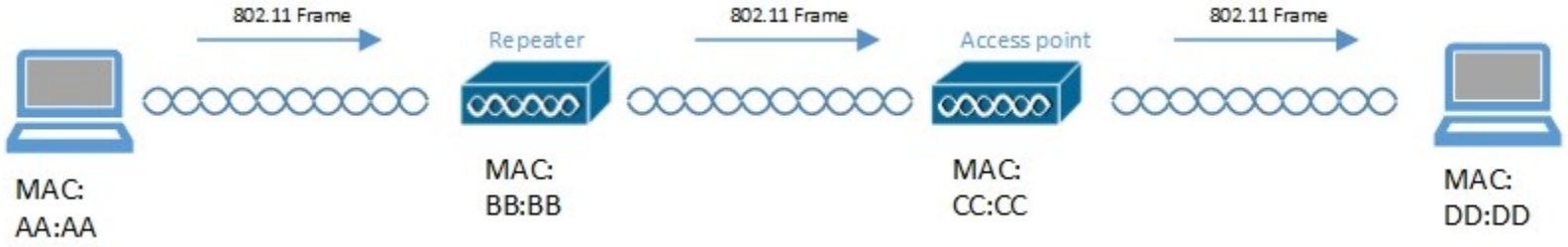
802.11 Adressering – Exempel

Hur skulle 802.11 adresseringen se ut i wireshark för scenariot nedan?

RA: *BB:BB*
TA: *AA:AA*
DA: *DD:DD*
SA: *AA:AA*

RA: *CC:CC*
TA: *BB:BB*
DA: *DD:DD*
SA: *AA:AA*

RA: *DD:DD*
TA: *CC:CC*
DA: *DD:DD*
SA: *AA:AA*



802.11 Frame Types

- Till skillnad från Ethernet använder 802.11 tre olika typer av frames

- Management frames
  - Management frames används av stationer för att ansluta eller lämna ett BSS
- Control frames
  - Control frames används för att assistera leveransen av data frames
- Data frames
  - Data frames bär data från övre-lager i OSI-modellen, d.v.s. de har en payload

802.11 Management frames

- Management frames används av stationer för att ansluta eller lämna ett BSS

- Management frames bär ingen data (payload) i 802.11 framen, istället använder den sig av specifika informationsfält i framen för att uföra funktioner i ett BSS
  - Eftersom de inte har någon payload och behöver förstås av alla anslutna klienter skickas management frames normalt okrypterat och oautentiserat

- För att säkra upp management frames kan tillägget 802.11w *Management Frame Protection (MFP)* användas
  - MFP förhindrar spoofing av management frames genom att lägga till en *MIC* (*message integrity check*, motsvarande HMAC)
  - MFP har traditionellt sett använts lite då stöd saknats hos klientenheter…
  - MFP-stöd är dock ett krav med den nya WPA3-certifieringen!

802.11 Management frames

Management frames:

- Association request/response
- Reassociation request/response
- Disassociation
- Probe request/response
- Beacon
- Authentication
- Deauthentication

802.11 Control frames

- Control frames används för att assistera leveransen av data frames
- De används i huvudsak för att ACKa unicast data frames
- De används också i specialfall för att begära åtkomst till en kanal (RTS) eller meddela att en sändning kan påbörja (CTS)

Control frames

- Request to send (RTS)
- Clear to send (CTS)
- Acknowledgment (ACK)
- Block ACK

802.11 Data frames

- Data frames innehåller data från övre-lager i OSI-modellen – de har en *payload*
- Payloaden i en 802.11 data frame krypteras vanligtvis av konfidentialitetsskäl
- En 802.11 data frame har en MAC header, en payload och en FCS-trailer (CRC)

- I moderna 802.11 nätverk är frame-typen *QoS Data,* eftersom den stöder QoS-klassificering (802.11e HCF)

802.11 WLAN Discovery

- Innan en klient kan ansluta till ett WLAN behöver den upptäcka tillgängliga BSS och säkerställa vilka parametrar som behövs för att ansluta

- En *beacon* management frame skickas ut av accesspunkter för att annonsera tillgängliga nätverk till klienter
- Beacon-framen innehåller förutom SSID all nödvändig information om ett BSS

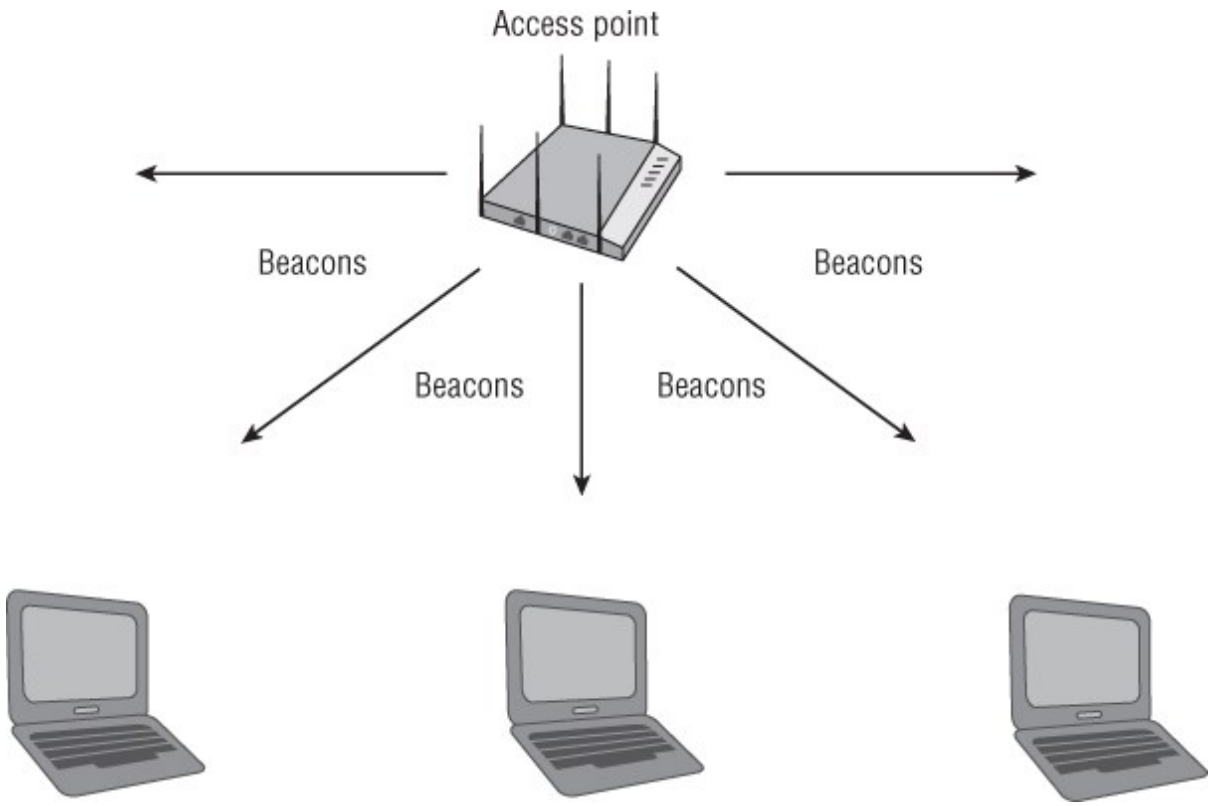
- Beacons broadcastas av en AP kontinuerligt – runt 10 frames per sekund

802.11 Beacon management frame

Beacon-framen innehåller bland annat:

- Landskod
- ”Spread Spectrum”-information
- Kanalinformation
- Data Rates
- SSID
- Säkerhetsinformation (T.ex. WPA2/WPA3)

802.11 Beacon management frame

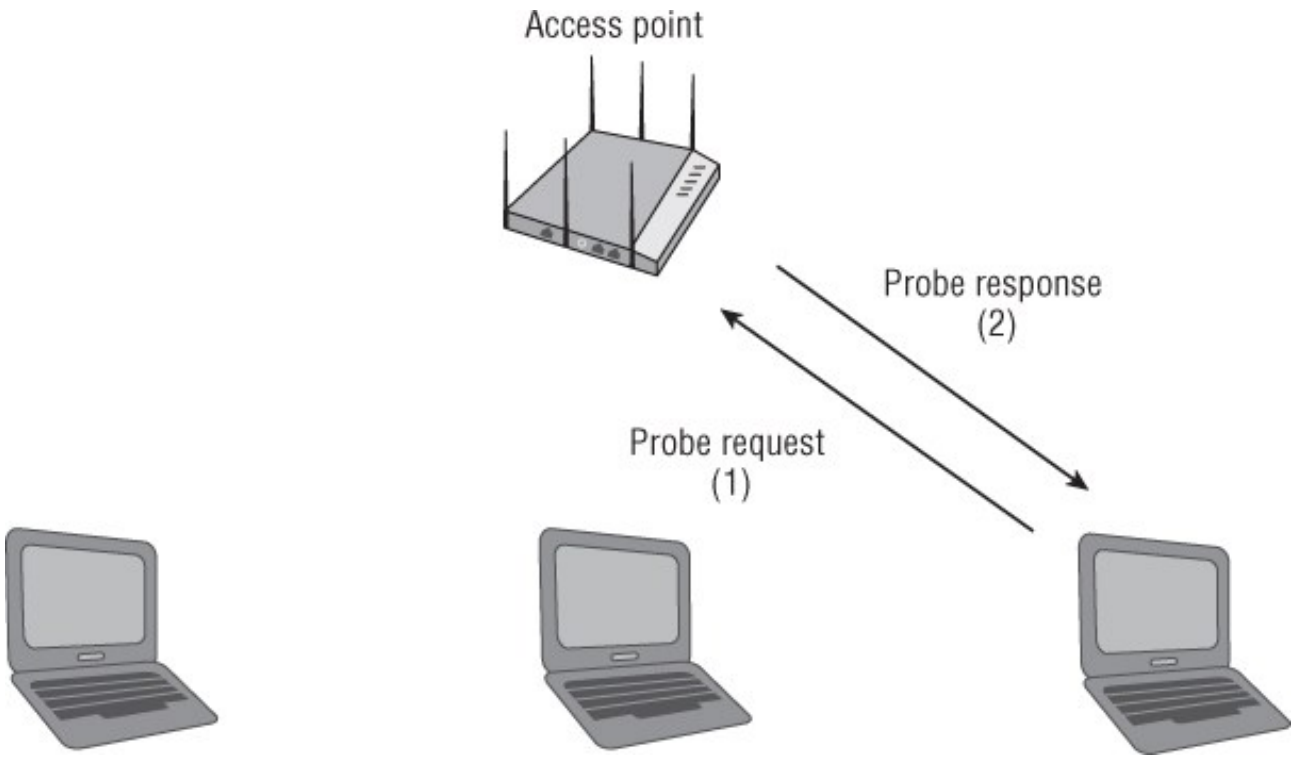


802.11 Probe request & response

- Om en klient använder beacons för WLAN Discovery kallas detta för *passiv skanning*
- *aktiv skanning* är istället när en klient direkt efterfrågar BSS parametrar från en accesspunkt genom att skicka en *probe request* för ett specifikt SSID

- En AP som hör en probe request för ett SSID den tillhandahåller kommer svara med en *probe response*
- Denna probe response innehåller samma typ av information som en beacon frame – d.v.s. all information som behövs för att ansluta

802.11 Probe request & response



802.11 Null Probe request

- Om klienten vill göra aktiv skanning för att hitta alla nätverk kan den skicka en s.k. *null probe request*
- En null probe request specificerar inte något SSID i förfrågan

- Accesspunkter som hör en null probe request kommer svara med en *probe response* för de SSID som den tillhandahåller

Ansluta till ett BSS

- Efter en klient har gjort WLAN Discovery kan den påbörja processen för att ansluta till ett specifikt BSS

- 802.11 Authentication
  - Authentication är första steget i processen
  - Authentication request/response frames
  - Klienterna autentiserar sig som 802.11 enheter (alternativt används en delad WEP-nyckel)
- Association
  - Association request/response
  - Varje klient tilldelas ett unikt AID (association ID)
  - Efter detta är klienten *associated* och ansluten till ett BSS på lager 2

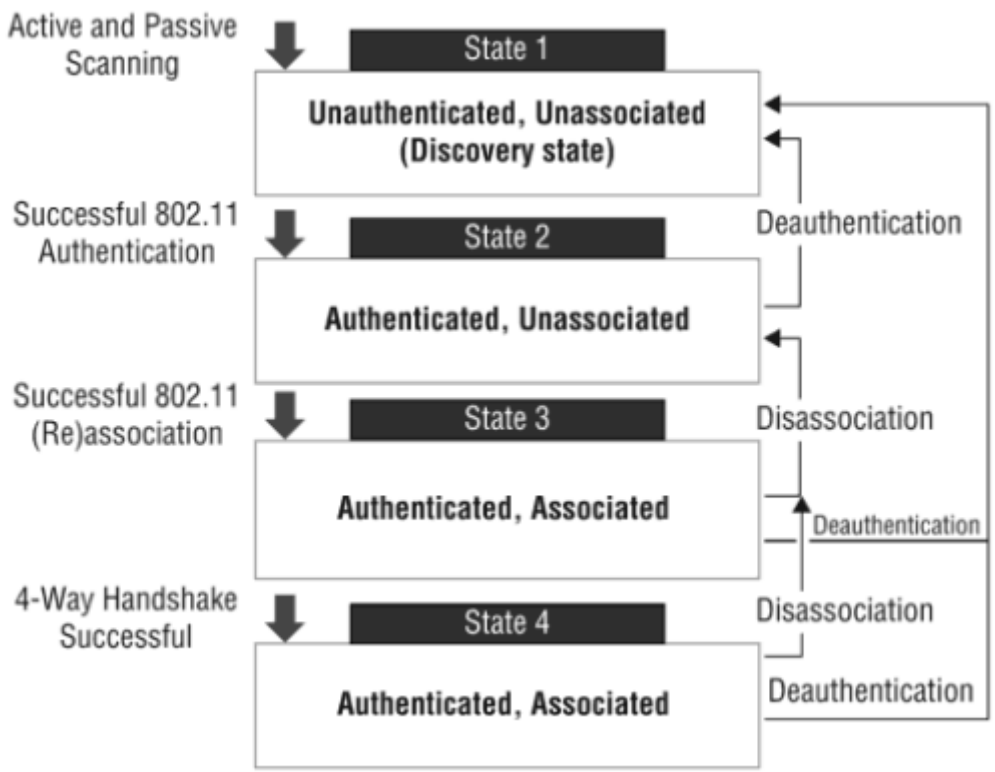
Ansluta till ett BSS

- Om nätverket är skyddat med WPA, WPA2 eller WPA3 kommer ett till autentiseringssteg för att autentisera sig och generera krypteringsnycklar
  - Genom ett ”4-way handshake”

- 802.11 Authentication
- Association
- RSN authentication

- Om RSN-autentisering krävs kommer en station inte lyckas skicka genom accesspunkten utan ytterligare autentisering

Ansluta till ett BSS – ”state machine”



OBS: Kallas även automaton eller tillståndsmaskin

Roaming

- Roaming är när en klient väljer att flytta sin anslutning mellan två accesspunkter utan att lämna ett WLAN
- Roamingbeslutet är inte standardiserat – det är upp till klientenhetens 802.11 implementation och algoritmer att bestämma när och hur roaming ska ske

- Beslutet bygger ofta på parametrar som mottagen signalstyrka till inblandade accesspunkter, störningar (noise), mängden retransmits eller bitfel

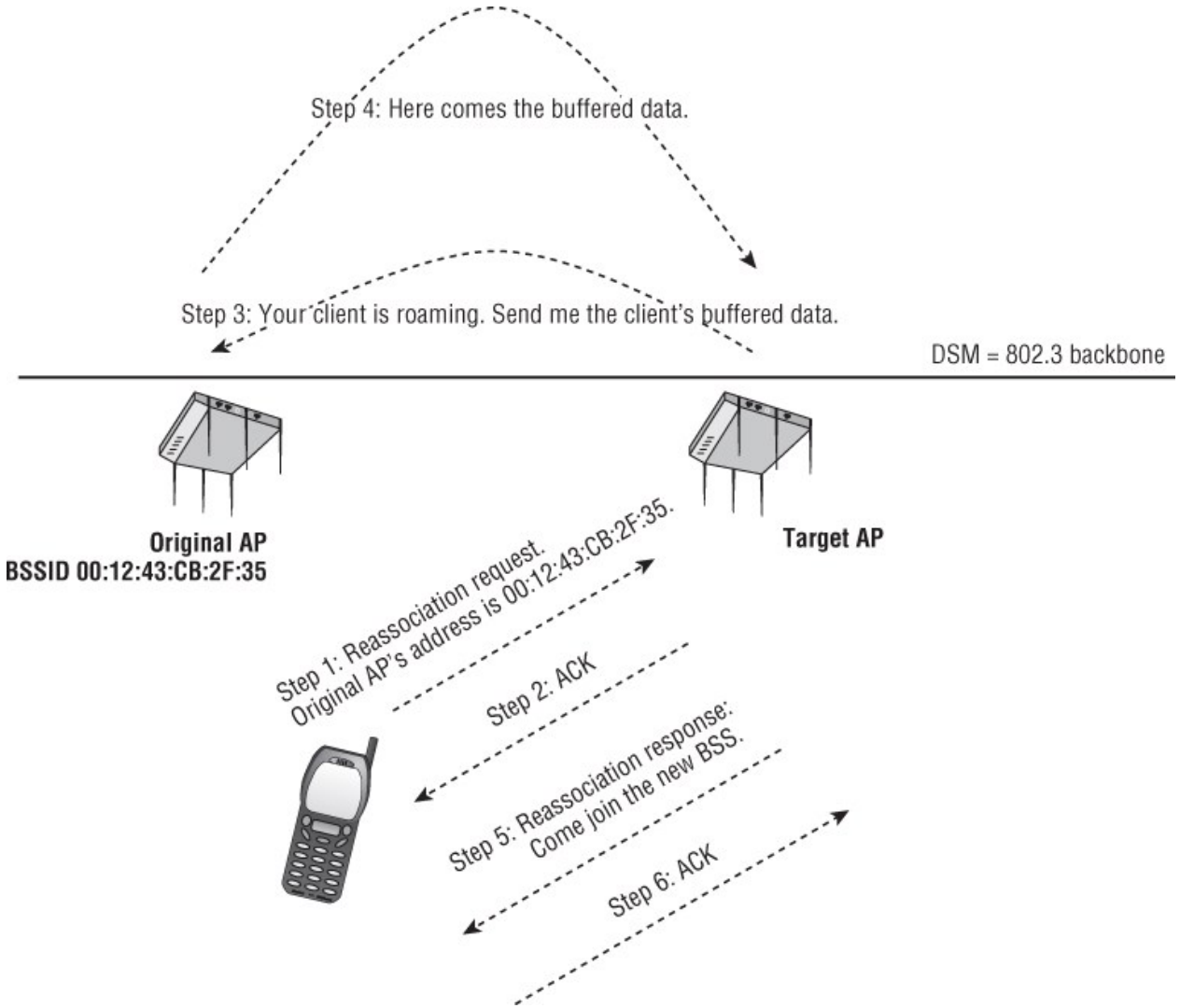
Roaming

- När en klientstation påbörjar roaming kommer den skicka en *reassociation request* frame till den nya accesspunkten

- Om accesspunkten kan tillhandahålla klienten kommer den svara med en *reassociation response* frame

- Den nya accesspunkten kommer ofta hämta buffrad klientdata via DS som den gamla accesspunkten inte har kunnat leverera under roamingprocessen (beroende på AP-vendor)

Roaming


Step 4: Here comes the buffered data.
Step 3: Your client is roaming. Send me the client's buffered data.
DSM = 802.3 backbone
Original AP
BSSID 00:12:43:CB:2F:35
Target AP
Step 1: Reassociation request.
Original AP's address is 00:12:43:CB:2F:35.
Step 2: ACK
Step 5: Reassociation response:
Come join the new BSS.
Step 6: ACK

Deauthentication & Disassociation

- *Deauthentication frames* och *disassociation frames* används av klienter eller APs för att lämna ett WLAN

Eftersom *authentication* sker före *association*:

- Om en klient skickar en disassociation frame kommer den fortfarande vara autentiserad (på 802.11 nivå)
- Om en klient skickar en deauthenticion frame kommer den helt lämna och behöver gå igenom alla steg

Summering

Management frames:

- Beacon
- Probe request/response
- Association request/response
- Reassociation request/response
- Disassociation
- Deauthentication

Control frames:

- RTS/CTS
- ACK
- Block ACK (HCF)

Data frames:

- Data
- QoS Data (HCF)

JÖNKÖPING UNIVERSITY

School of Engineering

Nätverksdesign – Trådlösa Nätverk

Del 3
Trådlös säkerhet

Trådlös säkerhet

- Eftersom 802.11 använder ett delat medium, tillgängligt för alla inom räckvidd, finns det en mängd risker att ta hänsyn till
- Trådlös säkerhet har haft dåligt rykte historiskt sett (och i viss mån idag)
  - Säkerhetsfunktioner i första IEEE 802.11-standarden gav inte tillräcklig konfidentialitet eller integritet
- Väldesignade och noggrant skyddade nätverk med moderna protokoll och lösningar kan ge god säkerhet där konfidentialitet och integritet är skyddat

Trådlös säkerhet

Vilka säkerhetsrisker eller hot associerar ni med trådlös teknik?

Vad krävs för trådlös säkerhet?

- Confidentiality and integrity
  - Stark kryptering på frames och integritetsverifiering (MIC)
- Authentication, authorization, and accounting (AAA)
  - Användare ska autentiseras för att säkerställa att endast auktoriserade enheter och användare kan nå nätverket
- Nätverkssegmentering
  - VLANs och olika typer av regler och filter kan begränsa åtkomsten till nätverksresurser (WLAN och LAN)
- Monitoring
  - Nätverket och användning ska övervakas och loggas
  - Wireless Intrusion Detection System kan övervaka och varna om attacker, intrångsförsök och skadligt beteende
- Policy
  - En trådlös säkerhetspolicy för nätverket bör finnas, i denna specificeras regler och detaljer om användningen av det trådlösa nätverket
  - Till den trådlösa säkerhetspolicyn bör olika stöddokument finnas, t.ex. en *BYOD-policy* och en *RogueAP-policy*

”Legacy-säkerhet” - autentisering

- Legacy 802.11 autentisering specificerade två metoder:
- Open System authentication
  - Ingen autentisering av användare
  - Klient och AP utbyter information för att verifiera 802.11-funktionalitet
    - Authentication request / response
  - Efter autentisering skickas data okrypterat, alternativt läggs statisk WEP-kryptering på efteråt
    - Wired equivalent privacy (WEP)
- Shared Key authentication
  - Klient enheter måste autentisera sig genom att presentera den statiska WEP-nyckel som är konfigurerad för nätverket
  - Efter autentisering används samma nyckel för att kryptera 802.11 data frames

”Legacy-säkerhet” – Shared key authentication

Shared Key authentication

1. Klienten skickar en authentication request till AP:n
2. AP:n svarar genom att skicka tillbaka en utmaning i klartext som ska krypteras
3. Klienten krypterar utmaningen med sin WEP-nyckel och skickar tillbaka det krypterade resultatet
4. AP:n föröker avkryptera utmaningen med sin WEP-nyckel och jämför resultatet med den ursprungliga utmaningen
   - Om klientens svar matchar utmaningen skickar den tillbaka en *authentication reply* och klienten blir autentiserad
   - Om klientens svar inte matchar utmaningen, eller om den inte kan avkryptera klientens svar, kommer den skicka tillbaka ett svar och neka autentiseringen

”Legacy-säkerhet”– Statisk WEP-kryptering

- WEP är en krypteringsmetod för lager2 som använder RC4-algoritmen
- WEP använder 64- eller 128-bit kryptering
  - Med 128-bit kryptering konfigureras båda enheterna med en statisk-nyckel på 26 hexadecimala tecken eller 13 ASCII-tecken

WEP är tänkt att ge:

- Confidentiality – Konfidentialitet genom att kryptera data
- Access Control – Genom autentisering med en delad nyckel
- Data Integrity – En checksumma för att säkerställa integritet (ICV) räknas ut innan kryptering och används för att säkerställa att datan inte har ändrats

”Legacy-säkerhet” – Statisk WEP-kryptering

- *Shared key authentication* och WEP-kryptering är knäckt sen länge
- Med shared key authentication kunde någon som avlyssnade trafiken spela in utmaningen i klartext samt det krypterade svaret och använda detta för att räkna fram WEP-nyckeln
- Även utan att förlita sig på en inspelad autentisering finns det sårbarheter i hur WEP implementerar krypteringen som gör att verktyg snabbt kan hitta krypteringsnyckeln enbart genom att granska krypterad trafik
- Eftersom WEP-kryptering använder statiska nycklar för kryptering kan vem som helst som känner till nyckeln avkryptera vilken frame som helst i nätverket

802.11i Robust Security

- 2004 publicerades 802.11i tillägget för säkerhet
  - 802.11i används idag och är del av den senaste publiceringen av 802.11-standarden

- 802.11i definierar användningen av 802.1x/EAP autentisering och pre-shared key (PSK) autentisering
- 802.11i beskriver också användningen av dynamiska krypteringsnycklar och starkare krypteringsmetoder och algoritmer med TKIP/RC4 eller CCMP/AES
- Ett 802.11i-skyddat nätverk kallas för ett **Robust Security Network (RSN)**

OBS: TKIP och CCMP är krypteringsmetoder, RC4 och AES är krypteringsalgoritmer
Ni behöver inte förstå skillnaden eller detaljer om dessa för denna kurs

802.11i Robust Security

- Wi-Fi Alliance publicerade två nya säkerhetscertifieringar baserat på teknikerna definierat i 802.11i
- **WPA (*Wi-Fi Protected Access*)**
  - WPA släpptes innan 802.11i färdigställdes och var baserad på en draft av standarden
  - Eftersom WPA var tänkt som en direkt ersättning av WEP använde det fortfarande RC4 algoritmen men med den säkrare krypteringsmetoden TKIP
- **WPA2 (*Wi-Fi Protected Access 2*)**
  - WPA2 är baserat på den kompletta 802.11i-standarden
  - WPA2 ersätter WPA och använder en säkrare metod med CCMP/AES

- WPA och WPA2 finns i två varianter
  - **WPA(2) Personal** använder PSK-autentisering
  - **WPA(2) Enterpris**e använder 802.1x/EAP autentisering

802.11i Robust Security

802.11 standard	Wi-Fi Alliance certification	Authentication method	Encryption method	Cipher	Key generation
802.11 legacy		Open System or Shared Key	WEP	RC4	Static
	WPA-Personal	WPA Passphrase (also known as WPA PSK and WPA Preshared Key)	TKIP	RC4	Dynamic
	WPA-Enterprise	802.1X/EAP	TKIP	RC4	Dynamic
802.11-2012 (RSN)	WPA2-Personal	WPA2 Passphrase (also known as WPA2 PSK and WPA2 Preshared Key)	CCMP (mandatory) TKIP (optional)	AES (mandatory) RC4 (optional)	Dynamic
802.11-2012 (RSN)	WPA2-Enterprise	802.1X/EAP	CCMP (mandatory) TKIP (optional)	AES (mandatory) RC4 (optional)	Dynamic

Dynamiska krypteringsnycklar

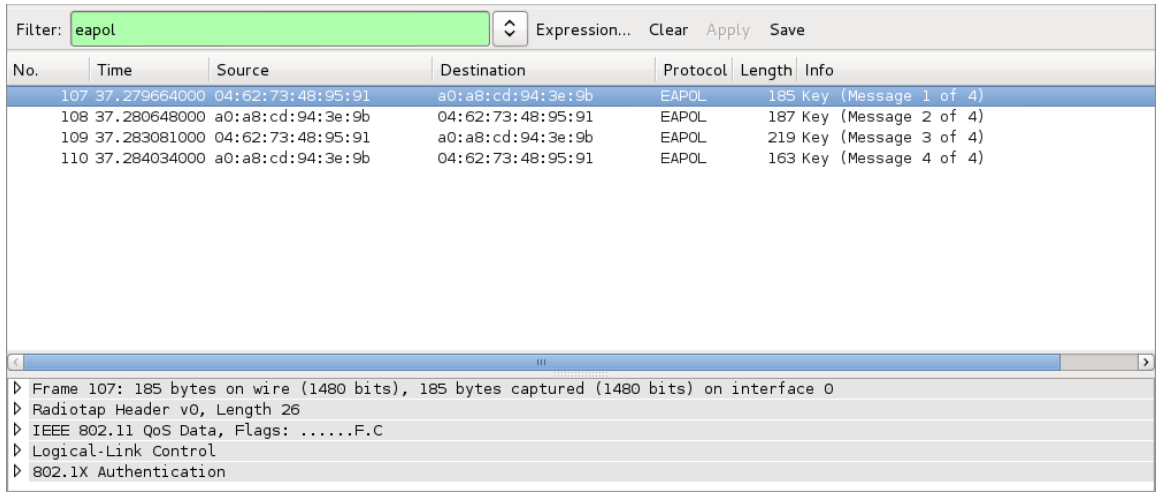
- Med **statiska krypteringsnycklar** används samma nyckel för både kryptering och avkryptering för **alla användare** i ett BSS
  - Om någon får tag i en krypteringsnyckel kan vilken trafik som helst avkrypteras

- Med **dynamiska krypteringsnycklar** är nycklarna som används dynamiskt genererade för **varje användare och varje session**
  - Om någon får tag i en användares krypteringsnyckel kan endast data för den specifika användaren avkrypteras – och endast tills en ny nyckel genereras dynamiskt

- Krypteringsnycklarna är inte samma uppgifter som används för autentisering i RSN (*t.ex. PSK)*, däremot genereras dem vid autentisering
- Vi kan alltså ha dynamiska krypteringsnycklar även fast autentiseringen alltid använder samma uppgifter

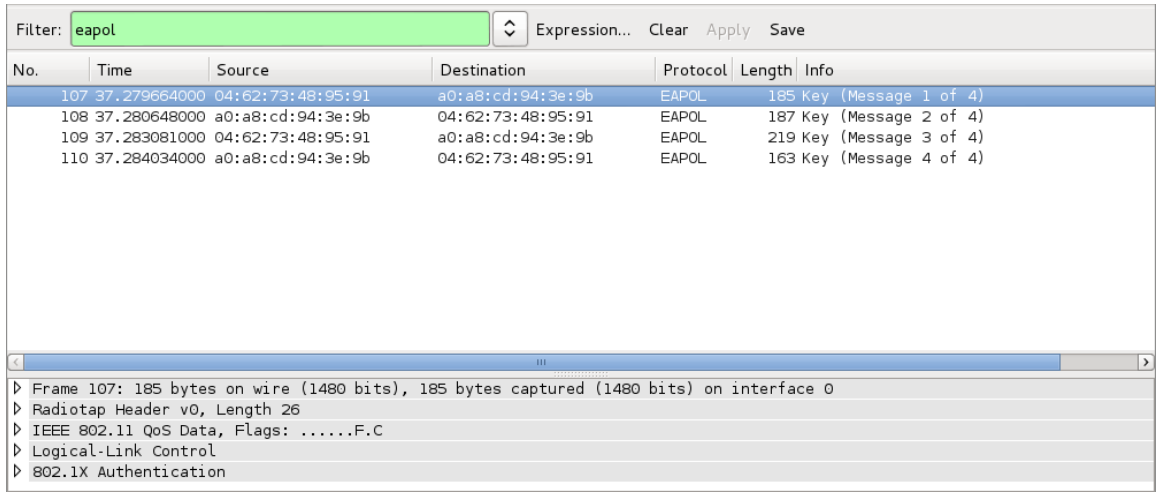
WPA & WPA2 – RSN Authentication

- I WPA & WPA2 behöver två stationer först göra vanlig 802.11 *authentication* och *association* innan de påbörjar **RSN Authentication**
- Denna process sker genom ett 4-way handshake
  - Dynamiska krypteringsnycklar genereras som ett direkt resultat av denna autentisering



WPA & WPA2 – RSN Authentication

- Om du känner till en WPA2-PSK och lyckas spela in en användares 4-way handshake kan du räkna ut vilken krypteringsnyckel som används för sessionen
  - Ni kommer testa detta i veckans labb!



WPA2 Personal

- WPA2 personal skiljer sig inte konceptuellt från tidigare shared key authentication
- Båda teknikerna använder en delad ”hemlig” nyckel som konfigureras på klient och AP
- I WPA2 är PSK ett enkelt lösenord på 8-63 tecken

- Eftersom PSK i praktiken är ett lösenord kan vanliga attacker mot lösenord även användas mot PSK (t.ex. brute force-attacker eller offline dictionary-attacker)
- Liknande rekommendationer gäller för PSK som för lösenord:
  - Var vaksam mot social engineering
  - Slumpmässiga lösenord är mer säkra än vanliga fraser och ord
  - Lösenordsstyrkan sätts av lösenordets entropi, sökyta och längd
  - Lösenordet ska vara långt och använda en kombination av stora och små bokstäver, siffror och specialtecken

WPA2 Personal – Offline dictionary attack

- PSK kombineras med unik information från 4-way handshake för att generera krypteringsnycklar
- Om du känner till PSK och spelar in 4-way handhake kan du avkryptera en användares data
  - Att spela in 4-way handshake är enkelt – gör en packet capture under autentiseringen

- Om du **inte** känner till PSK, kan du testa olika alternativ mot 4-way handshake för att se om det går att avkryptera
  - “Reverse engineering” tills du hittar ett matchande PSK
- Detta görs inte manuellt – det finns verktyg och databaser som testar åt dig!
  - Verktyget kan använda lösenordsläckor och databaser över vanliga lösenord
  - Verkyget skulle också kunna försöka testa alla möjliga kombinationer tills något matchar

Är WPA2 Personal mycket säkrare än WEP?

Ja absolut!

- Även fast autentiseringen är baserad på PSK är det stor skillnad i hur autentiseringen går tillväga (4-way handshake)
- Vidare är krypteringsnycklarna I WPA2 inte samma som PSK och delas inte av användare
- CCMP/AES ger säker kryptering medan WEP/RC4 är algoritmiskt svagt och har många sårbarheter
- Även fast det finns attacker mot WPA2 Personal kommer ett starkt PSK ta många år att knäcka om man tvingas testa alla möjliga kombinationer (brute force)

- WEP ska aldrig användas i moderna nätverk!

Hur komplext bör ett PSK vara?

- Beror på…

- Wi-Fi Alliance rekommenderar ett PSK med minst 20 tecken och en blandning av siffror, stora/små bokstäver och specialtecken

WPA2 Enterprise

- WPA2 Enterprise använder *802.1x port-based access control* och *Extensible Authentication Protocol (EAP)* för autentisering

- Rätt konfigurerat är WPA2 Enterprise ett säkrare alternativ än WPA2 personal
  - EAP-metoder kan använda användarnamn och lösenord eller certifikatsbaserad autentisering
  - Eftersom det inte längre finns någon preshared key är nätverket inte längre sårbar till samma typer av lösenordsbaserade attacker som WPA2 Personal
  - Med WPA2 Enterprise har vi fortfarande ett 4-way handshake, men denna bygger inte på ett och samma PSK – Resultatet av EAP kommer användas som input till 4-way handshake

WPA2 Enterprise – 802.1X

- 802.1X är port-baserad network access control
- Syftet är att släppa igenom eller neka åtkomst genom en nätverksport genom autentisering med en server (t.ex. en RADIUS-server)
- 802.1X är inte en standard bara för 802.11 utan kan användas även för switchar

- 802.1X består av tre olika roller:
- Supplicant
- Authenticator
- Authentication server (AS)

WPA2 Enterprise – 802.1X

Supplicant:

- Klienten som begär åtkomst betecknas som en *supplicant*
- Klienten har unika autentiseringsuppgifter som behöver verifieras av en *authentication server*

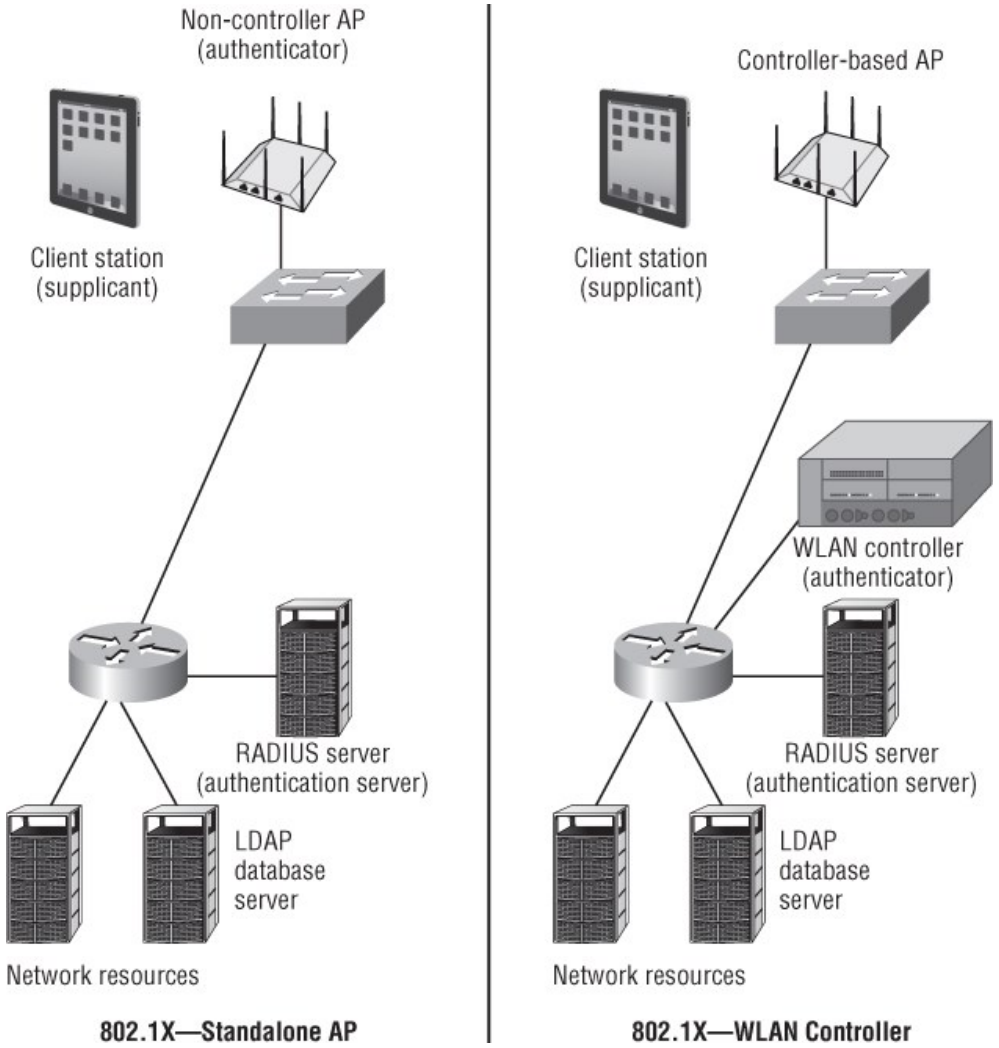
Authenticator:

- Enheten med authenticator-rollen blockerar eller släpper igenom trafik genom en nätverksport
- För 802.1x i Ethernet är authenticator ofta en switch
- I 802.11 är authenticator antingen en autonom AP eller en WLC

Authentication server:

- Authentication servern validerar uppgifterna från klienten och meddelar resultatet till authenticator-enheten

WPA2 Enterprise – 802.1X



WPA2 Enterprise – EAP types

- 802.1X ger port-baserad access control, men vi behöver fortfarande ett protokoll för själva autentiseringen
- Protokollet som används med 802.1x i WPA2 Enterprise är EAP (*Extensible Authentication Protocol)*

EAP kan ses som ett ramverk för autentisering och flera olika EAP-typer finns:

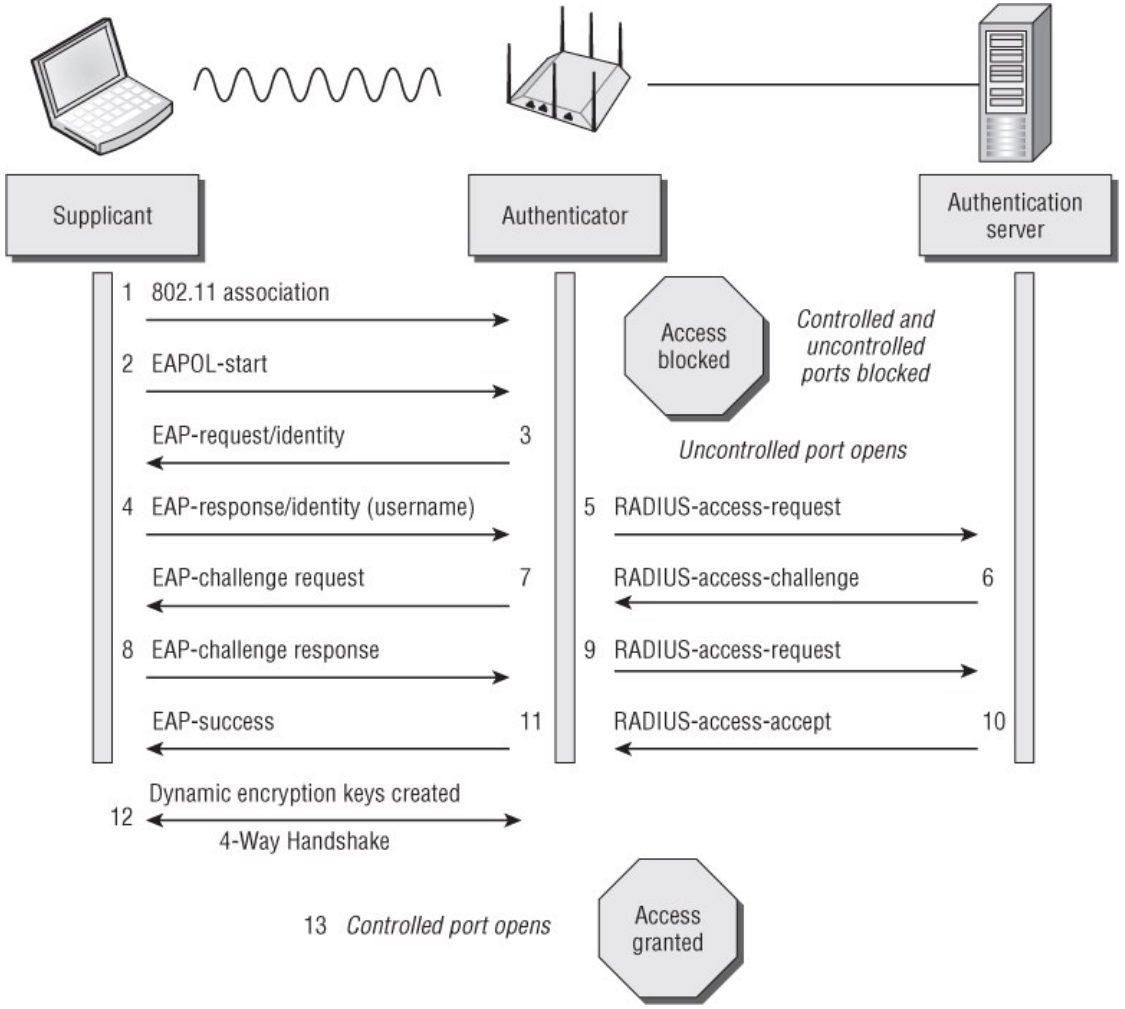
- Vissa EAP-typer autentiserar endast klient, medan andra autentiserar både klient och AP
- Vissa EAP-typer autentiserar med hjälp av certifikat, medan andra endast kräver användarnamn och lösenord
- EAP-typer baserat på certifikat och krypterade TLS-tunnlar är generellt sett mycket säkrare

WPA2 Enterprise – EAP types

	EAP-MD5	EAP-LEAP	EAP-TLS	EAP-TTLS	PEAPv0 (EAP-MSCHAPv2)	PEAPv0 (EAP-TLS)	PEAPv1 (EAP-GTC)	EAP-FAST
Security Solution	RFC-3748	Cisco proprietary	RFC-5216	RFC-5281	IETF draft	IETF draft	IETF draft	RFC-4851
Digital Certificates —Client	No	No	Yes	Optional	No	Yes	Optional	No
Digital Certificates —Server	No	No	Yes	Yes	Yes	Yes	Yes	No
Client Password Authentication	Yes	Yes	N/A	Yes	Yes	No	Yes	Yes
PACs—Client	No	No	No	No	No	No	No	Yes
PACs—Server	No	No	No	No	No	No	No	Yes
Credential Security	Weak	Weak (depends on password strength)	Strong	Strong	Strong	Strong	Strong	Strong (if Phase 0 is secure)
Encryption Key Management	No	Yes	Yes	Yes	Yes	Yes	Yes	Yes
Mutual Authentication	No	Debatable	Yes	Yes	Yes	Yes	Yes	Yes
Tunneled Authentication	No	No	Optional	Yes	Yes	Yes	Yes	Yes
Wi-Fi Alliance Supported	No	No	Yes	Yes	Yes	No	Yes	Yes

OBS: *Ni behöver inte memorera dessa för tentan*

WPA2 Enterprise – 802.1X/EAP auth



OBS: *Ni behöver inte memorera varje steg för tentan*

WPA3

- Wi-Fi Alliance lanserade WPA3-certifieringen i mitten av 2019
  - WPA3-Personal och Enterprise
  - WPA3 är en uppdaterad variant av RSN-autentisering

- WPA3-Personal
  - Använder en passphrase och en ny SAE-autentisering för att generera unik input till 4-way handshake
    - *”Simultaneous authentication of equals”*
    - SAE skyddar passphrasen mot offline dictionary attacker
      - Byter nycklar på en metod likt diffie hellman
      - vi går inte igenom SAE i kursen
  - Kräver 802.11w Protected management frames
    - Skydd mot spoofing och DoS-attacker standard med WPA3
- WPA3-Enterprise
  - Samma 802.1x/EAP autentisering som WPA2
  - Kräver 802.11w Protected management frames
  - Starkare kryptografi
    - *WPA3-Enterprise 192-Bit*

WPA3

- Både WPA3-Personal och Enterprise kan implementeras i *WPA3 Only* eller *WPA3 Transition* mode
  - *WPA3-Personal Only*
  - *WPA3-Personal Transition*
  - *WPA3-Enterprise Only*
  - *WPA3-Enterprise Transition*

- I *WPA3 Only* läge måste alla klienter använda sig av WPA3 och använda alla förbättringar
- I *WPA3 Transition* mode tillåts WPA2-klienter att autentisera med standard WPA2 och de behöver inte heller stödja alla funktioner i WPA3

- WPA3 är fortfarande relativt nytt, det kommer ta ett tag innan WPA2 är helt utbytt

JÖNKÖPING UNIVERSITY

School of Engineering

Nätverksdesign – Trådlösa Nätverk

Del 3 (Fortsättning)
Trådlös säkerhet

Wireless security

- I förra delen diskuterade vi användningen av protokoll for RSN-autentisering och kryptering med WPA2 och WPA3
- Detta är grunden för säkerhet i trådlösa nätverk!

Andra vanliga skyddsåtgärder är:

- Nätverkssegmentering
- Captive portals
- Hidden SSID
- VPN vid användning av Wi-Fi
- Wireless intrusion detection systems

Nätverkssegmentering

- Segmentering handlar om nätverksdesign snarare än en specifik funktion
- Med segmentering kan vi dela in olika typer av trådlösa användare i olika säkerhetszoner med olika regler för åtkomst
- Segmentering kan ske på flera olika sätt, t.ex. med brandväggar, routrar, VLAN och RBAC (role based access control)

- *T.ex. Användare på WLAN Students ska inte nå nätverksresurser, däremot får användare på WLAN Employees nå dessa*

Captive portal

- En captive portal är en webb-portal som klienter måste interagera med efter de har anslutit till ett WLAN
- Nätverket styr om webbtrafik från en klientenhet till portal-sidan, t.e.x. genom DNS
- Innan klienten tillåts skicka data genom en AP måste den först acceptera eller autentisera sig i portalens webbsida

- Till exempel kan en klient behöva:
  - Acceptera regler för nätverket
  - Identifiera sig med t.ex. email eller telefonnummer
  - Autentisera sig genom att ange giltiga inloggningsuppgifter

Captive portal

- Captive portals används ofta i öppna nätverk
- Notera att en captive portal **inte** krypterar en användares trafik efter de har passerat portalen
- Ett öppet gäst nätverk med en captive portal skickar alltså trafik okrypterat

- Det går att köra både WPA2/3 och Captive portals samtidigt
  - Det är bättre att köra t.ex. med delad publik nyckel och captive portal för gästnätverk än att köra helt okrypterat

- Ett tredje alternativ är en standard som kallas för Wi-Fi Enhanced open, vilket gör det möjligt att aktivera kryptering, utan autentisering, i öppna nätverk

Captive portal – Wi-Fi Enhanced open

- Nyfiken?

https://www.wi-fi.org/beacon/dan-harkins/wi-fi-certified-enhanced-open-transparent-wi-fi-protections-without-complexity

https://datatracker.ietf.org/doc/html/rfc8110

Valfri läsning, ej i kursen ☺

Hidden SSID

- Många APs ger möjlighet att använda ett dolt SSID
  - Funktionen kallas ibland: ’Hidden SSID’, ’SSID cloaking’ eller ’Broadcast SSID’
- Med ett dolt SSID kommer SSID-fältet i en beacon vara tom, och en klient som passivt skannar efter nätverk kommer inte upptäcka nätverket
  - Tanken är att klienter som inte specifikt vet om namnet och skickar en riktad *probe request* inte kommer upptäcka nätverket
- Detta ger ett svagt skydd för ett WLAN eftersom SSID fortfarande är synligt i andra 802.11 frames
  - Många verktyg kommer finna nätverket oavsett
  - Vem som helst i räckvidd kan öppna wireshark och hitta SSID

VPN vid användning av Wi-Fi

- Innan WPA2 fanns ibland en policy på företag som krävde användningen av VPN för att nå företagsresurser över Wi-Fi
- Även om en policy för VPN är mer ovanlig idag finns det fortfarande användningsområden för tekniken för Wi-Fi

- Vanligast idag är att VPN används på klienter när man kopplar upp sig på public hotspots eller gästnätverk

Wireless Intrusion Prevention Systems (WIPS)

- ***Wireless intrusion prevention systems*** kan upptäcka och hindra trådlösa attacker
- Alternativt används en ***wireless intrusion detection system*** som endast loggar när en incident sker

En typisk WIPS fungerar enligt klient-server model och har två komponenter:

WIPS-server

- WIPS-servern samlar in data, utför analys, och är en central punkt för övervakning av händelser
- WIPS-servern använder signaturer, beteenden samt analys av protokoll och RF spektrum för att upptäcka hot
- Baserat på typ av hot tar WIPS-servern antingen en åtgärd för att stoppa ett hot eller larmar

Sensorer

- WIPS-sensorer placeras på strategiska platser i nätverket där de samlar in data om klienter och deras trafik, samt RF-spektrumet
- Sensorerna rapporterar tillbaka till WIPS-servern för analys

Wireless Intrusion Prevention Systems (WIPS)

- WIDS/WIPS kan implementeras som en egen säkerhetslösning, eller så kan det implementeras i AP/WLC
- Cisco WLCs kan agera en enkel IDS med LAP i *monitor mode* som agerar som sensorer

Trådlösa attacker

- Eftersom Wi-Fi är så lättillgängligt finns många attacker och hot och de ses ibland som en lätt måltavla

Ett WLAN kan bli måltavla för

- Attackerare som vill nå ett företags resurser, klientdata eller sabotera
- Attackerare som vill använda ett WLAN för attacker mot andra mål
  - Spammers, hackers eller personer som utför andra olagliga aktiviteter
- Grannen, som bara vill åt Internet

Rogue Access Points

- När det gäller trådlösa hot pratas det mycket om s.k. **Rogue APs**

- En rouge AP är en AP som befinner sig i samma område som en organisations enheter, men som inte hanteras av organisationen själv
  - Cisco WLC listar alla accesspunkter som hörs av anslutna LAPs som en Rogue AP

- De flesta rogue APs är harmlösa – de är helt enkelt grannarnas APs som upptäcks trådlöst

Rogue Access Points

Rogue Summary

Active Rogue APs	61	Detail
Active Rogue Clients	2	Detail
Adhoc Rogues	0	Detail
Rogues on Wired Network	0	

Top WLANs

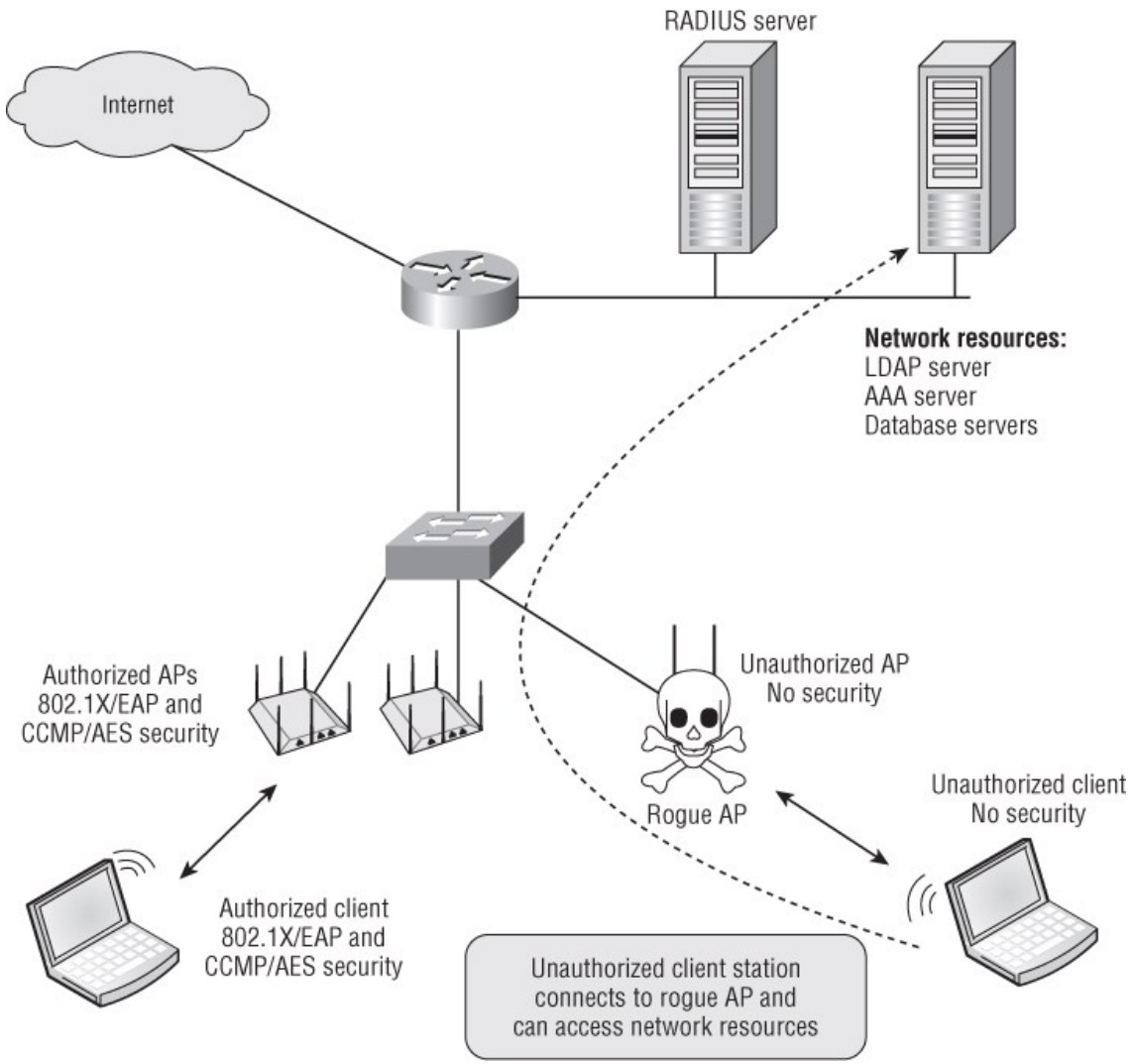
Profile Name	# of Clients	
Demo	1	Detail

Rogue Access Points

- En ”wired rogue AP” som har en koppling till en organisations DS kan orsaka stor skada och kan kringå organisationens normala säkerhetsåtgärder

- De flesta rogue APs som kopplas in på företags-LAN sker av anställda utan ont uppsåt, t.ex. för att få bättre täckning

Wired Rogue Access Points



Peer-to-Peer Attacker

- Precis som för ethernet kan trådlösa användare attackera varandra genom olika lager 2 och lager 3 attacker
- Klienter som är anslutna till samma SSID befiner sig i samma L2-segment och L3-segment

- Här är det viktigt att korrekt nätverkssegmentering existerar, för att på så sätt kunna sätta regler för hur användare får kommunicera med varandra
- Eftersom de flesta WLAN-användare bara behöver åtkomst till Internet eller resurser på företagets LAN har vissa APs en *Client Isolation* funktion
- *Client Isolation* hindrar klienter på samma WLAN att kommunicera med varandra

Eavesdropping

- Eftersom all data skickas i ett öppet medium finns möjligheten för vem som helst inom räckvidd att försöka avlyssna nätverket
- *Eavesdropping* sker med hjälp av PCAP-verktyg som t.ex. Wireshark
- De flesta länder har lagar som gör det olagligt att avlyssna elektromagnetisk kommunikation utan behörighet

Encryption cracking

- *Encryption cracking* syftar till tekniker som försöker erhålla krypteringsnycklar eller på annat sätt avkryptera data

- För encryption cracking krävs ofta att krypterad 802.11 data spelas in och verktyget kan sedan försöka lista ut vilken nyckel som används

- Med tillgång till en krypteringsnyckel kan 802.11 data avlyssnas och avkrypteras i realtid

Wireless Denial of Service (DoS)

- Denial of service på trådlösa nätverk är relativt enkelt eftersom det är ett delat medium – fyll mediet med data eller stör ut kanalen
- Denial of Service kan också ske genom att skicka spoofade *deauthentication*- eller *disassociation-frames* till klienter eller AP

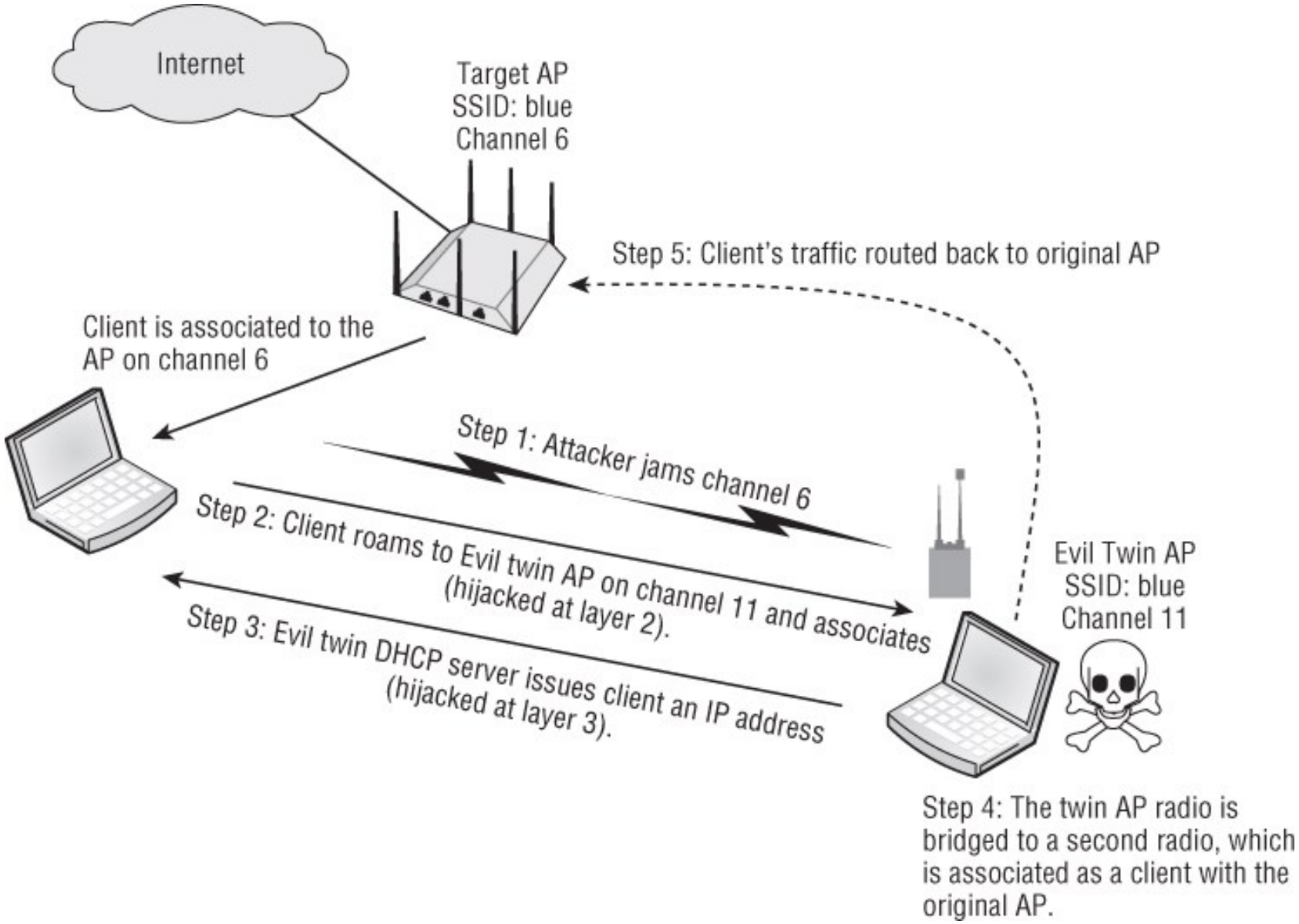
- Denna typ av spoofade deauthentication frames används ibland som en åtgärd mot rouge APs i WIPS system eller WLC
  - OBS: detta kan vara olagligt!

Wireless MITM - *Evil twin attack*

- En evil twin attack är en typ av *man-in-the-middle* attack mot trådlösa klienter
- Syftet med en evil twin attack är att lura en användare att ansluta till en attackerares AP istället för en AP som tillhandahålls av det nätverk användaren förväntar sig

En evil twin attack kan ske på följande sätt:

- En Evil Twin AP konfigureras med samma SSID och säkerhet som den riktiga AP:n
- Attackeraren gör en kontinuerlig DoS mot måltavlan – t.ex. genom att spoofa deauthentication frames
- När klienten försöker återansluta blir evil twin AP:n en giltig kandidat och kan eventuellt väljas automatiskt
- För att klienten inte ska upptäcka attacken kan evil twin AP:n vara ansluten till den riktiga APn, och styra om all trafik från den kapade klienten till den riktiga AP:n


Internet
Target AP
SSID: blue
Channel 6
Step 5: Client's traffic routed back to original AP
Client is associated to the
AP on channel 6
Step 1: Attacker jams channel 6
Step 2: Client roams to Evil twin AP on channel 11 and associates
(hijacked at layer 2).
Step 3: Evil twin DHCP server issues client an IP address
(hijacked at layer 3).
Evil Twin AP
SSID: blue
Channel 11
Step 4: The twin AP radio is
bridged to a second radio, which
is associated as a client with the
original AP.

Tack!

References

Chapter 8 & 9 in the course literature covers 802.11MAC

Chapters 16 & 17 in the course literature covers security and attacks

Note: Although interesting, it is not necessary to read and memorize everything in the course literature. Focus on the subjects brought up in the lecture-slides

Course literature:

Coleman, D. & Wescott, D. (2021). Exam CWNA-108. CWNA Certified Wireless Network Administrator Official Study Guide, 6th edition.